FICTIONAL COMPARISON. MFRS V1.2 answers derived from a fictional organisation; scored by the existing calculator. Not a customer report.

MK FRAUD INSIGHTS

COMPREHENSIVE FRAUD READINESS REPORT

Fraud exposure, target control environment and implementation programme

77.51
READINESS / 100

DEVELOPING
MATURITY BAND

PREPARED FOR

Fictional Owner-Managed Firm

Assessment reference · FX-P4

CONFIDENTIAL · AUTOMATED ANALYSIS · NOT INDEPENDENTLY REVIEWED

Contents

Management report — SECTIONS 1–9

1 · Where the organisation stands

2 · What is driving the position

3 · Where the material fraud exposure sits

4 · Fraud scenario portfolio

5 · The control environment management should build

6 · Who must own the response

7 · Decisions leadership must make

8 · What should happen, and in what order

9 · How management will know it is working

Analytical registers — APPENDICES A–F

A · Finding register	9 entries
B · Fraud risk register	8 entries
C · Control blueprint register	9 entries
D · Evidence requirement register	36 entries
E · 12-month action and assurance register	23 entries
F · Measurement register	9 entries

THE TWO HALVES OF THIS REPORT

Sections 1–9 are the management report: what the assessment shows, what it means, and what to do about it. Appendices A–F are the analytical registers behind those sections. They contain every finding, risk, control design, evidence requirement, action and measure, with the identifiers that connect them. The management sections state nothing the registers do not hold.

BASIS OF THIS REPORT

This report is produced by automated analysis of the recorded MK Fraud Readiness assessment. It has not been independently reviewed. No evidence has been examined, no control has been tested for operating effectiveness, no personnel have been interviewed, and no assurance opinion is given. Assessment positions are self-reported by the organisation. Recommended control designs, evidence requirements and operating measures are MK methodology: what good practice requires, not observations of what the organisation currently does.

FICTIONAL COMPARISON. MFRS V1.2 answers derived from a fictional organisation; scored by the existing calculator. Not a customer report.

The assessed readiness position

77.51	Developing	9	9	9
READINESS SCORE OUT OF 100	MATURITY BAND	DOMAINS ASSESSED	MATERIAL FINDINGS	CONTROL DESIGNS RECOMMENDED

Domain readiness profile



Fraud Leadership and Governance	90.67	Strategic
Fraud Risk Identification	86.67	Strategic
Operational Fraud Controls	69.33	Structured
Fraud Detection Capability	87.50	Strategic
Fraud Incident Response	87.69	Strategic
Whistleblowing and Reporting Culture	88.33	Strategic
Digital and Identity Fraud Risk	30.43	Reactive
Fraud Culture and Awareness	85.56	Strategic
Continuous Improvement and Fraud Risk Monitoring	90.48	Strategic

Ordered as assessed. Positions are self-reported through the assessment and have not been independently verified.

EXECUTIVE INTERPRETATION

Management interpretation is added at generation. The analysis on this page stands without it.

The patterns beneath the score

The assessment produced 9 material findings. They resolve into 3 connected patterns, ordered by how much of the organisation's critical control population each one affects.

PATTERN	FINDINGS	CRITICAL	HARD GATE	MANAGEMENT QUESTION THIS RAISES
Identity and access challenge Digital and Identity Fraud Risk · Operational Fraud Controls	6	4	4	Is authority verified at the points where it can be misused?
Culture and continuous improvement Digital and Identity Fraud Risk · Fraud Culture and Awareness	2	Not recorded	Not recorded	Do people recognise fraud, and does the control environment learn?
Incident response and evidence integrity Digital and Identity Fraud Risk	1	Not recorded	Not recorded	When something is suspected, can we contain it and keep the evidence?

Every finding behind these patterns is listed in Appendix A.

WHY THIS MATTERS

Management interpretation is added at generation. The analysis on this page stands without it.

Exposure by control family

8 fraud risks arise from the assessed position. They concentrate in 3 exposure families.

EXPOSURE FAMILY	RISKS	DOMAINS AFFECTED	WHAT THE ORGANISATION IS EXPOSED TO
Identity and access challenge	5	D8 · D3, D8	Is authority verified at the points where it can be misused?
Culture and continuous improvement	2	D8 · D9	Do people recognise fraud, and does the control environment learn?
Incident response and evidence integrity	1	D8	When something is suspected, can we contain it and keep the evidence?

Full risk statements, causes and treatment directions are in Appendix B. Risks are derived from assessed control positions; no likelihood or monetary value is assigned, because the assessment does not support one.

MANAGEMENT IMPLICATION

Management interpretation is added at generation. The analysis on this page stands without it.

Fraud scenario portfolio

Conditional pathways derived from the recorded control position. Each shows how it could begin, how it could progress, the control response that would interrupt it, and what management could observe first. No allegation that any event has occurred.

PATHWAY	HOW IT COULD BEGIN	HOW IT COULD PROGRESS	INTERRUPTION POINT	WARNING INDICATORS	LINKS
A compromised or impersonated identity is used to change a sensitive profile, instruction or transaction IDENTITY IMPERSONATION	A customer, employee, supplier or counterparty is activated or materially changed without an independent verification step.	An actor presents an impersonated or manipulated identity to gain access, payment, credit, benefit or authority under another party's name.	Security Operations must monitor authentication, credential, profile, device and transaction signals across material identity-bearing systems, define takeover indicators and alert thresholds, and route suspected identity misuse into the separate investigation and containment process.; The process owner must define the risk points requiring verification, including customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting. Apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records and confirmation of contact details through independently obtained channels. Retain results and evidence under applicable data-protection obligations, require documented approval for exceptions, and trigger re-verification for sensitive profile or banking changes.	• Activation before verification, an unapproved exception, or a sensitive change without re-verification. • An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population. • Credential reset, device change or profile amendment • Identity data differs across trusted records • Sensitive transaction follows a new or unusual session	RISK-001, RISK-002

FICTIONAL COMPARISON. MFRS V1.2 answers derived from a fictional organisation; scored by the existing calculator. Not a customer report.

PATHWAY	HOW IT COULD BEGIN	PROGRESS	INTERRUPTION POINT	INDICATORS	LINKS
Privileged access is used to alter a value-bearing record, entitlement or audit trail PRIVILEGED ACCESS MISUSE	A privileged, administrative or emergency-access account remains usable without independent periodic review.	An actor uses privileged access to alter a record, entitlement or transaction and relies on weak recertification or monitoring to avoid timely challenge.	IT Security must maintain a complete sensitive-access inventory, require named identities and strong authentication, enforce least privilege and session logging, and remove access when the business justification ends; periodic recertification is handled by the separate access-review control.; IT Security must reconcile the complete sensitive-access and administrator population to current owners and role requirements at least quarterly, obtain an independent keep/remove decision from system owners, record exceptions and close removals within the defined service level; emergency and service accounts are included.; System owners must export the complete active-user access population on a defined cycle, obtain business-owner keep/remove decisions against current responsibilities, route exceptions to IT for closure and reconcile leaver and mover removals to the HR feed.	• An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population. • Missed review, unknown access or removal overdue beyond the defined service level. • Emergency or administrator access outside the role pattern • Unusual record or entitlement change • Access review exception remains overdue	RISK-003, RISK-004, RISK-006

The control programmes

The 9 recommended control designs group into 3 programmes. Each is one coherent piece of work with one accountable executive.

PROGRAMME	CONTROLS	EVIDENCE	MEASURES	ACCOUNTABLE	HORIZON
Identity and access challenge	6	23	6	Chief Operating Officer	60 days, 90 days
Culture and continuous improvement	2	8	2	Chief Technology Officer	90 days, 60 days
Incident response and evidence integrity	1	5	1	Chief Technology Officer	90 days

Individual control designs are in Appendix C; the evidence each requires is in Appendix D.

> **CONTROL PROGRAMME SYNTHESIS**
>
> Management interpretation is added at generation. The analysis on this page stands without it.

Programme detail

Identity and access challenge

6 CONTROLS

Is authority verified at the points where it can be misused?

Accountable: Chief Operating Officer
Evidence expected · 23 items across 6 controls
Delivery horizon: 60 days, 90 days
Effectiveness measures · 6

Controls: CI-D3-Q04, CI-D3-Q08, CI-D8-Q01, CI-D8-Q04, CI-D8-Q08, CI-D8-Q09

Culture and continuous improvement

2 CONTROLS

Do people recognise fraud, and does the control environment learn?

Accountable: Chief Technology Officer
Evidence expected · 8 items across 2 controls
Delivery horizon: 90 days, 60 days
Effectiveness measures · 2

Controls: CI-D8-Q03, CI-D9-Q02

Incident response and evidence integrity

1 CONTROLS

When something is suspected, can we contain it and keep the evidence?

Accountable: Chief Technology Officer
Evidence expected · 5 items across 1 controls
Delivery horizon: 90 days
Effectiveness measures · 1

Controls: CI-D8-Q10

The governance model

Accountability is expressed as roles, not individuals. The assessment does not identify people, and this report does not infer them.

ROLE	STANDING	CONTROLS	DECISIONS	EVIDENCE	ESCALATION RESPONSIBILITY
Chief Technology Officer	executive accountability	5	5	Not recorded	Not recorded
Chief Operating Officer	executive accountability	3	Not recorded	Not recorded	Not recorded
Chief People Officer	executive accountability	1	1	Not recorded	Not recorded
Technology and information security	process ownership	7	Not recorded	28	A high-risk role group with low report rate, or a real payment instruction actioned without out-of-band verification.
Named business process owners	process ownership	1	Not recorded	4	Not recorded
People, learning and ethics	process ownership	1	Not recorded	4	Not recorded
Risk function	process ownership	Not recorded	Not recorded	Not recorded	Any missed quarterly review, unassigned account or removal overdue beyond 10 business days.

The decision agenda

DECISION	WHY NOW	RECOMMENDED DIRECTION	OWNER	CONSEQUENCE OF DELAY
Approve accountable executive mandates and escalation authority for priority remediation.	Hard-gate, governance and maturity-limiting controls require authority to allocate resources and resolve blockers.	Name one accountable executive per linked control and approve a 30-day escalation route.	Chief Technology Officer 60 days	Priority controls remain ownerless or blocked and the maturity reading remains constrained.
Choose and record remediation rather than passive acceptance for Critical and High risks.	Plausible consequence pathways require an explicit leadership treatment decision.	Approve linked treatments; any temporary acceptance must name an owner, expiry and compensating control.	Chief Technology Officer 60 days	Known risk pathways remain untreated without a documented acceptance basis.
Approve the target control standards management will implement across the priority risk areas.	Functions need one design baseline rather than independent interpretations of the findings.	Adopt the control-improvement register; deviations require documented oversight approval.	Chief Technology Officer 60 days	Partial or inconsistent designs fail to address the causal pathway.
Approve specialist capacity and resources for high-difficulty controls.	High-difficulty controls cannot meet target periods without committed capacity.	Fund the named supporting functions and require a resource-confirmed delivery plan.	Chief Technology Officer 60 days	The highest-complexity gaps remain open despite nominal approval.
Approve prerequisite-first sequencing for dependent improvements.	Dependent controls cannot operate reliably before prerequisite ownership, data or processes exist.	Use authoritative roadmap dependency IDs and escalate threatened prerequisites.	Chief Technology Officer 60 days	Downstream controls are implemented on incomplete foundations.
Approve a fixed fraud-risk implementation and control-effectiveness review cadence.	The linked registers require continuing governance to become a managed programme.	Require monthly implementation reporting and quarterly control-effectiveness review through the organisation's management and oversight route.	Chief People Officer 60 days	Actions lose momentum, exceptions remain open and management receives the control position too late to intervene.

A recommended direction is MK methodology. The decision remains management's.

The 12-month implementation programme

9 implementation actions, followed by 7 embed-and-evidence checkpoints, and 7 assure-and-review checkpoints across the 12-month programme. 23 programme objects in total, each with an owner, a deliverable and a test that shows it is complete.

HORIZON	WORK TYPE	COUNT	PROGRAMMES ADVANCED IN THIS HORIZON
60 days	Implement	6	Identity and access challenge · Culture and continuous improvement
90 days	Implement	3	Identity and access challenge · Culture and continuous improvement · Incident response and evidence integrity
3-6 months	Embed & evidence	7	Identity and access challenge · Culture and continuous improvement · Incident response and evidence integrity
6-12 months	Assure & review	7	Identity and access challenge · Culture and continuous improvement · Incident response and evidence integrity

Every programme item, with its dependency and completion criterion, is in Appendix E.

IMPLEMENTATION SYNTHESIS

Management interpretation is added at generation. The analysis on this page stands without it.

The measurement framework

Each programme carries effectiveness measures drawn from the control designs behind it. These are the signals management should expect to see, not a claim that they exist today.

PROGRAMME	MEASURES	CONTROLS	ACCOUNTABLE FOR REPORTING
Identity and access challenge	6	6	Chief Operating Officer
Culture and continuous improvement	2	2	Chief Technology Officer
Incident response and evidence integrity	1	1	Chief Technology Officer

The individual measures are in Appendix F.

> **CONCLUSION**
>
> Management interpretation is added at generation. The analysis on this page stands without it.

Finding register

Every material finding the assessment produced. "Assessment indication" is what the responses record; it is self-reported and has not been verified.

ID	DOMAIN	ASSESSMENT INDICATION	MATERIALITY	FRAUD MECHANISM	RISK	CONTROL
MF-D8-Q08 D8-Q08	Digital and Identity Fraud Risk	Initial / ad hoc This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	maturity constraint GATE	Identity misuse can continue when takeover, impersonation and unusual identity-bearing activity are not surfaced for timely challenge.	RISK-CONTROL-D8-Q08	CI-D8-Q08
MF-D3-Q04 D3-Q04	Operational Fraud Controls	Partially designed This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	maturity constraint GATE	Access granted without a current role basis can enable a person to initiate, approve or alter activity beyond legitimate responsibility.	RISK-UNAUTHORISED-ACCESS	CI-D3-Q04
MF-D8-Q04 D8-Q04	Digital and Identity Fraud Risk	Partially designed This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	control failure GATE	Excess or unmanaged sensitive access allows records, controls or confidential data to be altered or concealed.	RISK-UNAUTHORISED-ACCESS	CI-D8-Q04
MF-D8-Q01 D8-Q01	Digital and Identity Fraud Risk	Partially designed This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	control failure GATE	An unverified or impersonated identity allows a fraudulent party to receive goods, payments, credit, benefits or system access under someone else's name.	RISK-CONTROL-D8-Q01	CI-D8-Q01
MF-D8-Q03 D8-Q03	Digital and Identity Fraud Risk	Initial / ad hoc This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Most payment-diversion and account-compromise attacks begin with a convincing message to a person, so the workforce is the control surface that is actually attacked.	RISK-CONTROL-D8-Q03	CI-D8-Q03
MF-D8-Q09 D8-Q09	Digital and Identity Fraud Risk	Initial / ad hoc This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Access that was once justified can remain available after role change or operational change and enable unauthorised alteration or concealment.	RISK-CONTROL-D8-Q09	CI-D8-Q09
MF-D3-Q08 D3-Q08	Operational Fraud Controls	Partially designed This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Stale access after role change or exit can be used to initiate, change or conceal activity outside current responsibilities.	RISK-CONTROL-D3-Q08	CI-D3-Q08
MF-D8-Q10 D8-Q10	Digital and Identity Fraud Risk	Partially designed This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Without a tested response route, an identity compromise can continue after detection and its scope, losses and affected parties may remain unclear.	RISK-CONTROL-D8-Q10	CI-D8-Q10
MF-D9-Q02 D9-Q02	Fraud Culture and Awareness	Consistently operating This is an assurance priority, not a failed control. The strong self-reported response should be validated with operating evidence.	assurance priority	New joiners learn behaviour from whoever trains them, so without a formal baseline an existing workaround or bypass is transmitted as normal practice.	RISK-CONTROL-D9-Q02	CI-D9-Q02

Fraud risk register

Risks implied by the assessed control positions. No likelihood, monetary value or incident frequency is assigned, because the assessment does not support one.

ID	RISK	CURRENT CONTROL POSITION	REQUIRED TREATMENT	OWNER ROLE
RISK-CONTROL-D8-Q01 MF-D8-Q01	**Because the self-assessment records "The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm" as "Partially designed"; the expected control standard is therefore not yet met, there is a risk that an unverified or impersonated identity allows a fraudulent party to receive goods, payments, credit, benefits or system access under someone else's name. Consequence pathway: compromised or privileged access can alter records and transactions; Digital misuse can evade prevention and monitoring.**	Digital and Identity Fraud Risk: Partially designed: Partially designed but not fully implemented	The process owner must define the risk points requiring verification, including customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting. Apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records and confirmation of contact details through independently obtained channels. Retain results and evidence under applicable data-protection obligations, require documented approval for exceptions, and trigger re-verification for sensitive profile or banking changes.	COO / CFO
RISK-CONTROL-D8-Q08 MF-D8-Q08	**Because the self-assessment records "The organisation can detect identity misuse, account takeover or impersonation" as "Initial / ad hoc"; the expected control standard is therefore not yet met, there is a risk that identity misuse can continue when takeover, impersonation and unusual identity-bearing activity are not surfaced for timely challenge. Consequence pathway: compromised or privileged access can alter records and transactions; Digital misuse can evade prevention and monitoring.**	Digital and Identity Fraud Risk: Initial / ad hoc: Exists only informally or inconsistently	Security Operations must monitor authentication, credential, profile, device and transaction signals across material identity-bearing systems, define takeover indicators and alert thresholds, and route suspected identity misuse into the separate investigation and containment process.	Chief Technology Officer
RISK-UNAUTHORISED-ACCESS MF-D3-Q04, MF-D8-Q04	**Because role-based access is not completely reviewed and removed when responsibilities change, there is a risk that a user or compromised credential uses excess access to initiate, approve or conceal unauthorised activity. Consequence pathway: data or access-control obligations may be breached; stakeholders lose trust in system integrity; system records and segregation of duties cannot be relied upon; transactions or assets are manipulated for direct loss.**	Digital and Identity Fraud Risk: Partially designed: Partially designed but not fully implemented; Operational Fraud Controls: Partially designed: Partially designed but not fully implemented	IT Security must maintain a complete sensitive-access inventory, require named identities and strong authentication, enforce least privilege and session logging, and remove access when the business justification ends; periodic recertification is handled by the separate access-review control. System owners must maintain a current role-to-access matrix, require business-owner approval against the requester's current duties before granting access, separate incompatible initiation and approval rights, and retain the request, approval and provisioning trail.	COO
RISK-CONTROL-D3-Q08 MF-D3-Q08	**Because the self-assessment records "System and data access is reviewed periodically and removed when no longer required" as "Partially designed"; the expected control standard is therefore not yet met, there is a risk that stale access after role change or exit can be used to initiate, change or conceal activity outside current responsibilities. Consequence pathway: access or supplier-control weakness can enable unauthorised payments or manipulation; Preventive controls may not match current roles or approved suppliers.**	Operational Fraud Controls: Partially designed: Partially designed but not fully implemented	System owners must export the complete active-user access population on a defined cycle, obtain business-owner keep/remove decisions against current responsibilities, route exceptions to IT for closure and reconcile leaver and mover removals to the HR feed.	COO

ID	RISK	POSITION	REQUIRED TREATMENT	OWNER ROLE
RISK-CONTROL-D8-Q03 MF-D8-Q03	**Because the self-assessment records "Employees receive training on phishing, social engineering and digital impersonation attempts" as "Initial / ad hoc"; the expected control standard is therefore not yet met, there is a risk that most payment-diversion and account-compromise attacks begin with a convincing message to a person, so the workforce is the control surface that is actually attacked. Consequence pathway: compromised or privileged access can alter records and transactions; Digital misuse can evade prevention and monitoring.**	Digital and Identity Fraud Risk: Initial / ad hoc: Exists only informally or inconsistently	The security awareness owner must deliver role-relevant training covering payment-instruction and bank-detail-change requests, executive impersonation, urgency and secrecy pressure, credential-harvesting pages and voice or messaging impersonation; reinforce with periodic simulations targeted at high-risk roles such as finance and procurement, measure report rate as well as click rate, provide a one-click reporting route with feedback, and require verification through an independently obtained channel for any payment or bank-detail instruction.	Chief Technology Officer / Chief People Officer
RISK-CONTROL-D8-Q09 MF-D8-Q09	**Because the self-assessment records "Sensitive access and administrator rights are reviewed periodically" as "Initial / ad hoc"; the expected control standard is therefore not yet met, there is a risk that access that was once justified can remain available after role change or operational change and enable unauthorised alteration or concealment. Consequence pathway: compromised or privileged access can alter records and transactions; Digital misuse can evade prevention and monitoring.**	Digital and Identity Fraud Risk: Initial / ad hoc: Exists only informally or inconsistently	IT Security must reconcile the complete sensitive-access and administrator population to current owners and role requirements at least quarterly, obtain an independent keep/remove decision from system owners, record exceptions and close removals within the defined service level; emergency and service accounts are included.	Chief Technology Officer
RISK-CONTROL-D8-Q10 MF-D8-Q10	**Because the self-assessment records "The organisation can investigate and contain identity misuse, account takeover or impersonation" as "Partially designed"; the expected control standard is therefore not yet met, there is a risk that without a tested response route, an identity compromise can continue after detection and its scope, losses and affected parties may remain unclear. Consequence pathway: compromised or privileged access can alter records and transactions; Digital misuse can evade prevention and monitoring.**	Digital and Identity Fraud Risk: Partially designed: Partially designed but not fully implemented	Security Operations and Fraud Operations must maintain a response runbook for identity misuse covering session revocation, credential reset, account hold, customer or employee contact, evidence preservation, scope assessment, recovery, escalation and closure; the runbook is exercised periodically and material cases receive independent review.	Chief Technology Officer / Chief Operating Officer
RISK-CONTROL-D9-Q02 MF-D9-Q02	**Because the self-reported control position has not yet been independently validated with operating evidence, there is a risk that the reported control may not operate consistently across the full population, at the required frequency or under pressure. This does not assert a control defect. The potential financial, operational, legal and reputational consequence is set out in the linked impact fields below, and applies only if independent validation identifies a defect.**	Fraud Culture and Awareness: Consistently operating: Operating consistently in practice	Independently validate the reported control(s) across the complete population, required frequency and under pressure before relying on the self-assessment. If validation identifies a defect, apply: The People lead must include a fraud module in induction covering the fraud policy and prohibited conduct, how and where to report, the protection from retaliation, the consequences of dishonest conduct, and the fraud risks specific to the joiner's role; completion is required within a defined period of the start date, tracked against the joiner population from the HR system, extended to contractors with equivalent system or asset access, and overdue completion escalates to the hiring manager.	Chief People Officer

Control blueprint register

Recommended control standard for each finding. This is MK methodology: what good practice requires, not a description of what the organisation currently operates. The assessed state column records what the organisation reported for that control.

ASSESSED STATE KEY

- Partially designed: Partially designed but not fully implemented.; self-assessed and not independently verified.
- Initial / ad hoc: Exists only informally or inconsistently.; self-assessed and not independently verified.
- Consistently operating: Operating consistently in practice.; self-assessed and not independently verified.

ID	OBJECTIVE	RECOMMENDED DESIGN	ASSESSED	OWNER / OVERSIGHT	FREQUENCY	EFFECTIVENESS TEST
CI-D3-Q04 D3-Q04 60 days	**Close the material control weakness recorded for "System and data access is granted against current role requirements".**	System owners must maintain a current role-to-access matrix, require business-owner approval against the requester's current duties before granting access, separate incompatible initiation and approval rights, and retain the request, approval and provisioning trail.	STATE 1	Business system owners Risk / Internal Audit	Quarterly and on every joiner, mover or leaver event	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.
CI-D3-Q08 D3-Q08 60 days	**Close the material control weakness recorded for "System and data access is reviewed periodically and removed when no longer required".**	System owners must export the complete active-user access population on a defined cycle, obtain business-owner keep/remove decisions against current responsibilities, route exceptions to IT for closure and reconcile leaver and mover removals to the HR feed.	STATE 1	Business system owners Risk / Internal Audit	Quarterly and on every joiner, mover or leaver event	100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.
CI-D8-Q01 D8-Q01 60 days	**Close the material control weakness recorded for "The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm".**	The process owner must define the risk points requiring verification, including customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting. Apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records and confirmation of contact details through independently obtained channels. Retain results and evidence under applicable data-protection obligations, require documented approval for exceptions, and trigger re-verification for sensitive profile or banking changes.	STATE 1	Process owners for onboarding and activation Risk / Compliance	At every defined risk point and on sensitive change	100% of in-scope enrolments and activations carry completed verification before activation, with all exceptions approved.
CI-D8-Q03 D8-Q03 90 days	**Close the material control weakness recorded for "Employees receive training on phishing, social engineering and digital impersonation attempts".**	The security awareness owner must deliver role-relevant training covering payment-instruction and bank-detail-change requests, executive impersonation, urgency and secrecy pressure, credential-harvesting pages and voice or messaging impersonation; reinforce with periodic simulations targeted at high-risk roles such as finance and procurement, measure report rate as well as click rate, provide a one-click reporting route with feedback, and require verification through an independently obtained channel for any payment or bank-detail instruction.	STATE 2	Security awareness owner Information Security / Risk	At induction, at least annually, with periodic simulations	At least 95% completion, improving report rate and declining click rate across successive simulations.

FICTIONAL COMPARISON. MFRS V1.2 answers derived from a fictional organisation; scored by the existing calculator. Not a customer report.

ID	OBJECTIVE	RECOMMENDED DESIGN	ASSESSED	OVERSIGHT	FREQUENCY	TEST
CI-D8-Q04 D8-Q04 60 days	**Close the material control weakness recorded for "Access to sensitive systems, administrator rights and confidential data is restricted".**	IT Security must maintain a complete sensitive-access inventory, require named identities and strong authentication, enforce least privilege and session logging, and remove access when the business justification ends; periodic recertification is handled by the separate access-review control.	STATE 1	Identity and Access Management Information Security / Internal Audit	Continuous logging; quarterly recertification; event-driven removal	100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.
CI-D8-Q08 D8-Q08 90 days	**Close the material control weakness recorded for "The organisation can detect identity misuse, account takeover or impersonation".**	Security Operations must monitor authentication, credential, profile, device and transaction signals across material identity-bearing systems, define takeover indicators and alert thresholds, and route suspected identity misuse into the separate investigation and containment process.	STATE 2	Security operations with identity owners Information Security / Risk	Continuous logging and alerting; runbook exercised at least annually	All material identity-bearing systems are logged with takeover alerting active and the runbook exercised annually.
CI-D8-Q09 D8-Q09 60 days	**Close the material control weakness recorded for "Sensitive access and administrator rights are reviewed periodically".**	IT Security must reconcile the complete sensitive-access and administrator population to current owners and role requirements at least quarterly, obtain an independent keep/remove decision from system owners, record exceptions and close removals within the defined service level; emergency and service accounts are included.	STATE 2	Identity and Access Management Information Security / Internal Audit	Quarterly and after material role or system change	100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.
CI-D8-Q10 D8-Q10 90 days	**Close the material control weakness recorded for "The organisation can investigate and contain identity misuse, account takeover or impersonation".**	Security Operations and Fraud Operations must maintain a response runbook for identity misuse covering session revocation, credential reset, account hold, customer or employee contact, evidence preservation, scope assessment, recovery, escalation and closure; the runbook is exercised periodically and material cases receive independent review.	STATE 1	Security Operations and Fraud Operations Information Security / Risk	On every suspected case; annual or post-incident exercise	Every suspected identity-misuse case has timely containment, a recorded investigation and an accountable closure decision.
CI-D9-Q02 D9-Q02 60 days	**Validate that "Fraud awareness is included in employee onboarding or induction" operates to its exact expected standard.**	Independently validate that "Fraud awareness is included in employee onboarding or induction" operates to the expected standard (Induction includes fraud content covering policy, reporting routes, consequences and role-relevant risks, is completed within a defined period of joining, and covers contractors where they hold equivalent access.) across the complete population, required frequency and under pressure. This does not assert a control defect; if validation identifies one, apply the recommended control design: The People lead must include a fraud module in induction covering the fraud policy and prohibited conduct, how and where to report, the protection from retaliation, the consequences of dishonest conduct, and the fraud risks specific to the joiner's role; completion is required within a defined period of the start date, tracked against the joiner population from the HR system, extended to contractors with equivalent system or asset access, and overdue completion escalates to the hiring manager.	STATE 3	Human Resources / Learning and Development Risk / Compliance	On every joiner, within the defined completion period	At least 95% of joiners complete the fraud induction module within the defined period.

Evidence requirement register

What management should be able to produce for each recommended control. No evidence has been requested, received or examined.

Identity and access challenge

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-D3-Q04	**Access requests and approvals**	Whether the access requests and approvals provides operating evidence that System and data access is granted against current role requirements is implemented across the complete in-scope population.	Approval predates provisioning	Business system owners Quarterly and on every joiner, mover or leaver event
	Current role-to-access matrix	Whether the current role-to-access matrix provides operating evidence that System and data access is granted against current role requirements; System and data access is reviewed periodically and removed when no longer required is implemented across the complete in-scope population.	Approval predates provisioning	Business system owners Quarterly and on every joiner, mover or leaver event
	Provisioning audit trail	Whether the provisioning audit trail provides operating evidence that System and data access is granted against current role requirements is implemented across the complete in-scope population.	Approval predates provisioning	Business system owners Quarterly and on every joiner, mover or leaver event
	Segregation-of-duties exception decisions	Whether the segregation-of-duties exception decisions provides operating evidence that System and data access is granted against current role requirements is implemented across the complete in-scope population.	Approval predates provisioning	Business system owners Quarterly and on every joiner, mover or leaver event
CI-D8-Q08	**Alert definitions for takeover indicators**	Whether the alert definitions for takeover indicators provides operating evidence that The organisation can detect identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Covers authentication, profile change and transaction events together	Security operations with identity owners Continuous logging and alerting; runbook exercised at least annually
	Defined retention period and data-protection basis	Whether the defined retention period and data-protection basis provides operating evidence that The organisation can detect identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Covers authentication, profile change and transaction events together	Security operations with identity owners Continuous logging and alerting; runbook exercised at least annually
	Investigation runbook and a worked case example	Whether the investigation runbook and a worked case example provides operating evidence that The organisation can detect identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Covers authentication, profile change and transaction events together	Security operations with identity owners Continuous logging and alerting; runbook exercised at least annually
	Log coverage inventory for identity-bearing systems	Whether the log coverage inventory for identity-bearing systems provides operating evidence that The organisation can detect identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Covers authentication, profile change and transaction events together	Security operations with identity owners Continuous logging and alerting; runbook exercised at least annually
CI-D8-Q04	**Approval and business justification**	Whether the approval and business justification provides operating evidence that Access to sensitive systems, administrator rights and confidential data is restricted is implemented across the complete in-scope population.	Covers human, service, shared and emergency accounts	Identity and Access Management Continuous logging; quarterly recertification; event-driven removal

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	CHARACTERISTIC	OWNER / RECENCY
	Privileged-account register	Whether the privileged-account register provides operating evidence that Access to sensitive systems, administrator rights and confidential data is restricted is implemented across the complete in-scope population.	Covers human, service, shared and emergency accounts	Identity and Access Management Continuous logging; quarterly recertification; event-driven removal
	Privileged-session/access logs	Whether the privileged-session/access logs provides operating evidence that Access to sensitive systems, administrator rights and confidential data is restricted is implemented across the complete in-scope population.	Covers human, service, shared and emergency accounts	Identity and Access Management Continuous logging; quarterly recertification; event-driven removal
	Quarterly independent recertification	Whether the quarterly independent recertification provides operating evidence that Access to sensitive systems, administrator rights and confidential data is restricted is implemented across the complete in-scope population.	Covers human, service, shared and emergency accounts	Identity and Access Management Continuous logging; quarterly recertification; event-driven removal
	Removal tickets	Whether the removal tickets provides operating evidence that Access to sensitive systems, administrator rights and confidential data is restricted is implemented across the complete in-scope population.	Covers human, service, shared and emergency accounts	Identity and Access Management Continuous logging; quarterly recertification; event-driven removal
CI-D8-Q09	**Complete sensitive-access register**	Whether the complete sensitive-access register provides operating evidence that Sensitive access and administrator rights are reviewed periodically is implemented across the complete in-scope population.	Reconciles to the complete population	Identity and Access Management Quarterly and after material role or system change
	Quarterly recertification decisions	Whether the quarterly recertification decisions provides operating evidence that Sensitive access and administrator rights are reviewed periodically is implemented across the complete in-scope population.	Reconciles to the complete population	Identity and Access Management Quarterly and after material role or system change
	Role and business-justification evidence	Whether the role and business-justification evidence provides operating evidence that Sensitive access and administrator rights are reviewed periodically is implemented across the complete in-scope population.	Reconciles to the complete population	Identity and Access Management Quarterly and after material role or system change
CI-D3-Q08	**Complete user-access export**	Whether the complete user-access export provides operating evidence that System and data access is reviewed periodically and removed when no longer required is implemented across the complete in-scope population.	Covers the complete active-user population	Business system owners Quarterly and on every joiner, mover or leaver event
	Periodic review decisions	Whether the periodic review decisions provides operating evidence that System and data access is reviewed periodically and removed when no longer required is implemented across the complete in-scope population.	Covers the complete active-user population	Business system owners Quarterly and on every joiner, mover or leaver event
	Removal and exception tickets	Whether the removal and exception tickets provides operating evidence that Sensitive access and administrator rights are reviewed periodically; System and data access is reviewed periodically and removed when no longer required is implemented across the complete in-scope population.	Covers the complete active-user population	Business system owners / Identity and Access Management Quarterly and after material role or system change; Quarterly and on every joiner, mover or leaver event
CI-D8-Q01	**Defined verification risk points and required checks**	Whether the defined verification risk points and required checks provides operating evidence that The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm is implemented across the complete in-scope population.	Retention respects applicable data-protection obligations	Process owners for onboarding and activation At every defined risk point and on sensitive change

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	CHARACTERISTIC	OWNER / RECENCY
	Exception approvals	Whether the exception approvals provides operating evidence that The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm is implemented across the complete in-scope population.	Retention respects applicable data-protection obligations	Process owners for onboarding and activation At every defined risk point and on sensitive change
	re-verification records for sensitive changes	Whether the re-verification records for sensitive changes provides operating evidence that The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm is implemented across the complete in-scope population.	Retention respects applicable data-protection obligations	Process owners for onboarding and activation At every defined risk point and on sensitive change
	Verification records with source and date	Whether the verification records with source and date provides operating evidence that The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm is implemented across the complete in-scope population.	Retention respects applicable data-protection obligations	Process owners for onboarding and activation At every defined risk point and on sensitive change

Culture and continuous improvement

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-D9-Q02	**Completion records reconciled to the joiner population**	Whether the completion records reconciled to the joiner population provides operating evidence that Fraud awareness is included in employee onboarding or induction is implemented across the complete in-scope population.	Covers contractors with equivalent access	Human Resources / Learning and Development On every joiner, within the defined completion period
	Contractor coverage evidence	Whether the contractor coverage evidence provides operating evidence that Fraud awareness is included in employee onboarding or induction is implemented across the complete in-scope population.	Covers contractors with equivalent access	Human Resources / Learning and Development On every joiner, within the defined completion period
	Induction fraud module content	Whether the induction fraud module content provides operating evidence that Fraud awareness is included in employee onboarding or induction is implemented across the complete in-scope population.	Covers contractors with equivalent access	Human Resources / Learning and Development On every joiner, within the defined completion period
	Overdue escalation log	Whether the overdue escalation log provides operating evidence that Fraud awareness is included in employee onboarding or induction is implemented across the complete in-scope population.	Covers contractors with equivalent access	Human Resources / Learning and Development On every joiner, within the defined completion period
CI-D8-Q03	**Reporting route usage statistics**	Whether the reporting route usage statistics provides operating evidence that Employees receive training on phishing, social engineering and digital impersonation attempts is implemented across the complete in-scope population.	Links to an out-of-band verification requirement	Security awareness owner At induction, at least annually, with periodic simulations
	Role-relevant training content and completion records	Whether the role-relevant training content and completion records provides operating evidence that Employees receive training on phishing, social engineering and digital impersonation attempts is implemented across the complete in-scope population.	Links to an out-of-band verification requirement	Security awareness owner At induction, at least annually, with periodic simulations

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	CHARACTERISTIC	OWNER / RECENCY
	Simulation results including click and report rates	Whether the simulation results including click and report rates provides operating evidence that Employees receive training on phishing, social engineering and digital impersonation attempts is implemented across the complete in-scope population.	Links to an out-of-band verification requirement	Security awareness owner At induction, at least annually, with periodic simulations
	Verification procedure for payment and bank-detail instructions	Whether the verification procedure for payment and bank-detail instructions provides operating evidence that Employees receive training on phishing, social engineering and digital impersonation attempts is implemented across the complete in-scope population.	Links to an out-of-band verification requirement	Security awareness owner At induction, at least annually, with periodic simulations

Incident response and evidence integrity

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-D8-Q10	**Authentication and activity evidence**	Whether the authentication and activity evidence provides operating evidence that The organisation can investigate and contain identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Closure or recovery decision is recorded	Security Operations and Fraud Operations On every suspected case; annual or post-incident exercise
	Containment and investigation case records	Whether the containment and investigation case records provides operating evidence that The organisation can investigate and contain identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Closure or recovery decision is recorded	Security Operations and Fraud Operations On every suspected case; annual or post-incident exercise
	Exercise and lessons-learned records	Whether the exercise and lessons-learned records provides operating evidence that The organisation can investigate and contain identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Closure or recovery decision is recorded	Security Operations and Fraud Operations On every suspected case; annual or post-incident exercise
	Identity-misuse response runbook	Whether the identity-misuse response runbook provides operating evidence that The organisation can investigate and contain identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Closure or recovery decision is recorded	Security Operations and Fraud Operations On every suspected case; annual or post-incident exercise
	Recovery or notification decisions	Whether the recovery or notification decisions provides operating evidence that The organisation can investigate and contain identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Closure or recovery decision is recorded	Security Operations and Fraud Operations On every suspected case; annual or post-incident exercise

12-month action and assurance register

The full twelve-month programme. Not every row is initial implementation: later horizons operate each control through its required cycle and then review whether it is still effective. The work type on each row says which it is.

HORIZON	WORK TYPE	ACTION	OWNER	COMPLETION CRITERION	EFFECTIVENESS MEASURE
60 days	Implement	Apply immediate escalation at "Any missed quarterly review, unassigned account or removal overdue beyond 10 business days." and deliver the exact control design: System owners must maintain a current role-to-access matrix, require business-owner approval against the requester's current duties before granting access, separate incompatible initiation and approval rights, and retain the request, approval and provisioning trail.	COO	Access requests and approvals; Current role-to-access matrix; Provisioning audit trail; Segregation-of-duties exception decisions	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.
60 days	Implement	Apply immediate escalation at "Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours." and deliver the exact control design: IT Security must maintain a complete sensitive-access inventory, require named identities and strong authentication, enforce least privilege and session logging, and remove access when the business justification ends; periodic recertification is handled by the separate access-review control.	Chief Technology Officer	Approval and business justification; Privileged-account register; Privileged-session/access logs; Quarterly independent recertification; Removal tickets	100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.
60 days	Implement	Apply immediate escalation at "Activation before verification, an unapproved exception, or a sensitive change without re-verification." and deliver the exact control design: The process owner must define the risk points requiring verification, including customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting. Apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records and confirmation of contact details through independently obtained channels. Retain results and evidence under applicable data-protection obligations, require documented approval for exceptions, and trigger re-verification for sensitive profile or banking changes.	COO / CFO	Defined verification risk points and required checks; Exception approvals; re-verification records for sensitive changes; Verification records with source and date	100% of in-scope enrolments and activations carry completed verification before activation, with all exceptions approved.
60 days	Implement	Apply immediate escalation at "Unknown or unjustified access, missed review, or removal overdue beyond the agreed service level." and deliver the exact control design: IT Security must reconcile the complete sensitive-access and administrator population to current owners and role requirements at least quarterly, obtain an independent keep/remove decision from system owners, record exceptions and close removals within the defined service level; emergency and service accounts are included.	Chief Technology Officer	Complete sensitive-access register; Quarterly recertification decisions; Removal and exception tickets; Role and business-justification evidence	100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.

60 days	Implement	Apply immediate escalation at "Missed review, unknown access or removal overdue beyond the defined service level." and deliver the exact control design: System owners must export the complete active-user access population on a defined cycle, obtain business-owner keep/remove decisions against current responsibilities, route exceptions to IT for closure and reconcile leaver and mover removals to the HR feed.	COO	Complete user-access export; Current role-to-access matrix; Periodic review decisions; Removal and exception tickets	100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.
60 days	Implement	Independently validate that "Fraud awareness is included in employee onboarding or induction" holds across the complete population and record whether every minimum evidence characteristic is met.	Chief People Officer	Completion records reconciled to the joiner population; Contractor coverage evidence; Induction fraud module content; Overdue escalation log	At least 95% of joiners complete the fraud induction module within the defined period.
90 days	Implement	Apply immediate escalation at "A suspected takeover that cannot be reconstructed from logs, or a material system without identity logging." and deliver the exact control design: Security Operations must monitor authentication, credential, profile, device and transaction signals across material identity-bearing systems, define takeover indicators and alert thresholds, and route suspected identity misuse into the separate investigation and containment process.	Chief Technology Officer	Alert definitions for takeover indicators; Defined retention period and data-protection basis; Investigation runbook and a worked case example; Log coverage inventory for identity-bearing systems	All material identity-bearing systems are logged with takeover alerting active and the runbook exercised annually.
90 days	Implement	Apply immediate escalation at "A high-risk role group with low report rate, or a real payment instruction actioned without out-of-band verification." and deliver the exact control design: The security awareness owner must deliver role-relevant training covering payment-instruction and bank-detail-change requests, executive impersonation, urgency and secrecy pressure, credential-harvesting pages and voice or messaging impersonation; reinforce with periodic simulations targeted at high-risk roles such as finance and procurement, measure report rate as well as click rate, provide a one-click reporting route with feedback, and require verification through an independently obtained channel for any payment or bank-detail instruction.	Chief Technology Officer / Chief People Officer	Reporting route usage statistics; Role-relevant training content and completion records; Simulation results including click and report rates; Verification procedure for payment and bank-detail instructions	At least 95% completion, improving report rate and declining click rate across successive simulations.
90 days	Implement	Apply immediate escalation at "Suspected takeover not contained within the defined SLA, incomplete evidence or unresolved affected-party exposure." and deliver the exact control design: Security Operations and Fraud Operations must maintain a response runbook for identity misuse covering session revocation, credential reset, account hold, customer or employee contact, evidence preservation, scope assessment, recovery, escalation and closure; the runbook is exercised periodically and material cases receive independent review.	Chief Technology Officer / Chief Operating Officer	Authentication and activity evidence; Containment and investigation case records; Exercise and lessons-learned records; Identity-misuse response runbook; Recovery or notification decisions	Every suspected identity-misuse case has timely containment, a recorded investigation and an accountable closure decision.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Quarterly and on every joiner, mover or leaver event), with a management sample and any exceptions recorded.	COO	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.

3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Quarterly and on every joiner, mover or leaver event), with a management sample and any exceptions recorded.	COO	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (At induction, at least annually, with periodic simulations), with a management sample and any exceptions recorded.	Chief Technology Officer / Chief People Officer	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	At least 95% completion, improving report rate and declining click rate across successive simulations.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Continuous logging; quarterly recertification; event-driven removal), with a management sample and any exceptions recorded.	Chief Technology Officer	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Continuous logging and alerting; runbook exercised at least annually), with a management sample and any exceptions recorded.	Chief Technology Officer	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	All material identity-bearing systems are logged with takeover alerting active and the runbook exercised annually.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Quarterly and after material role or system change), with a management sample and any exceptions recorded.	Chief Technology Officer	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (On every suspected case; annual or post-incident exercise), with a management sample and any exceptions recorded.	Chief Technology Officer / Chief Operating Officer	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Every suspected identity-misuse case has timely containment, a recorded investigation and an accountable closure decision.
6-12 months	Assure & review	A management or assurance review of CI-D3-Q04 covering effectiveness, exception trend and dependency, evidenced against: 100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.	COO	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.
6-12 months	Assure & review	A management or assurance review of CI-D3-Q08 covering effectiveness, exception trend and dependency, evidenced against: 100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.	COO	100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.	100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.
6-12 months	Assure & review	A management or assurance review of CI-D8-Q03 covering effectiveness, exception trend and dependency, evidenced against: At least 95% completion, improving report rate and declining click rate across successive simulations.	Chief Technology Officer / Chief People Officer	At least 95% completion, improving report rate and declining click rate across successive simulations.	At least 95% completion, improving report rate and declining click rate across successive simulations.
6-12 months	Assure & review	A management or assurance review of CI-D8-Q04 covering effectiveness, exception trend and dependency, evidenced against: 100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.	Chief Technology Officer	100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.	100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.
6-12 months	Assure & review	A management or assurance review of CI-D8-Q08 covering effectiveness, exception trend and dependency, evidenced against: All material identity-bearing systems are logged with takeover alerting active and the runbook exercised annually.	Chief Technology Officer	All material identity-bearing systems are logged with takeover alerting active and the runbook exercised annually.	All material identity-bearing systems are logged with takeover alerting active and the runbook exercised annually.

FICTIONAL COMPARISON. MFRS V1.2 answers derived from a fictional organisation; scored by the existing calculator. Not a customer report.					
6-12 months	Assure & review	A management or assurance review of CI-D8-Q09 covering effectiveness, exception trend and dependency, evidenced against: 100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.	Chief Technology Officer	100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.	100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.
6-12 months	Assure & review	A management or assurance review of CI-D8-Q10 covering effectiveness, exception trend and dependency, evidenced against: Every suspected identity-misuse case has timely containment, a recorded investigation and an accountable closure decision.	Chief Technology Officer / Chief Operating Officer	Every suspected identity-misuse case has timely containment, a recorded investigation and an accountable closure decision.	Every suspected identity-misuse case has timely containment, a recorded investigation and an accountable closure decision.

Measurement register

The effectiveness test behind each recommended control, grouped by programme. These are the signals management should expect once the control operates.

Identity and access challenge

MEASURE	CONTROLS IT COVERS
100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.	CI-D3-Q04
100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.	CI-D3-Q08
100% of in-scope enrolments and activations carry completed verification before activation, with all exceptions approved.	CI-D8-Q01
100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.	CI-D8-Q04
All material identity-bearing systems are logged with takeover alerting active and the runbook exercised annually.	CI-D8-Q08
100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.	CI-D8-Q09

Culture and continuous improvement

MEASURE	CONTROLS IT COVERS
At least 95% completion, improving report rate and declining click rate across successive simulations.	CI-D8-Q03
At least 95% of joiners complete the fraud induction module within the defined period.	CI-D9-Q02

Incident response and evidence integrity

MEASURE	CONTROLS IT COVERS
Every suspected identity-misuse case has timely containment, a recorded investigation and an accountable closure decision.	CI-D8-Q10